SECURITY

Pentest Methodology Visual Guide

Think like an attacker —
with permission, scope, and a report.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

The Five Phases

Every test follows the same arc.

Time-box each phase — rabbit holes are the #1 pentest killer. Depth matters more than breadth on the target that counts.

STEP 2/6

Recon: Learn Without Touching

Passive first — the target shouldn't feel you yet.

- OSINT: domains, subdomains, certs, DNS history, employee tech footprints.
- Map the attack surface: every host, API, login page, forgotten staging box.
- Note technologies and versions — each one is a future search query.
- Stay passive: no scanning yet; respect scope like it's law (it is).

STEP 3/6

Enumeration: Touch and Catalog

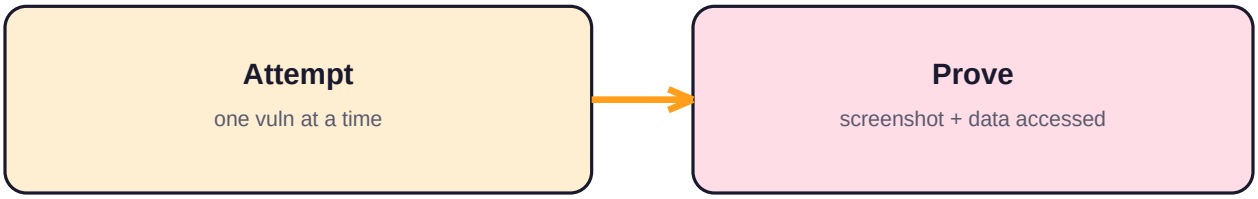
Active probing — build the target model.

- Port/service scanning, banner grabs, directory and API endpoint discovery.
- Identify versions precisely — 'Apache 2.4.x' isn't enough; get the patch level.
- Enumerate users, roles, and trust relationships where the scope allows.
- Document everything — enumeration notes become the exploit shortlist.

STEP 4/6

Exploitation: Prove Impact

Turn a finding into a demonstrated fact.



Never exploit beyond scope, never destroy data, never pivot without permission. A proved finding beats ten theoretical ones.

STEP 5/6

Post-Exploitation & Reporting

What access buys — and how to fix it.

- Post-exploit: demonstrate lateral movement and data reach WITHIN scope — that sells the risk.
- Clean up: remove shells, accounts, and artifacts; confirm with the client.
- Report: executive summary (risk in business terms) + technical findings (repro steps, evidence).
- Rate by real impact × likelihood; every finding gets a concrete remediation.

STEP 6/6

Rules of Engagement

The contract that keeps testing legal and safe.

- Written authorization with exact scope: IPs, domains, accounts, time windows.
- No-go list: production data destruction, DoS, social engineering — unless explicitly approved.
- Emergency contacts and a kill-switch phrase; test the comms channel day one.
- Retest after fixes — a finding isn't closed until the retest passes.

STEP ✓/✓

Key Takeaways

Pentest Methodology — Remember

- Five phases: recon → enumeration → exploitation → post-exploitation → reporting.
- Recon passive, enumeration active — document everything for the exploit shortlist.
- Exploit to prove impact, never beyond scope; clean up afterwards.
- Reports speak two languages: business risk for execs, repro steps for engineers.
- Rules of engagement in writing: scope, no-gos, contacts, kill-switch.
- Close the loop with retesting — fixes aren't done until verified.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev